REPORT · November 2026 · DRAFT, NOT PUBLISHED

State of public MCP servers

What 15,067 live Model Context Protocol servers from the official registry get right, what they skip, and what it costs the agents that connect to them.

Omer Shacham, AI agents & MCP architecture · Data collected 13 Nov 2026 with the open-source scanner mcp-readiness-check (v0.2.x).

15,067
servers reached (16,073 probed)

61%
pass every check

44%
of public servers accept any web Origin

10%
of login-protected servers can't be discovered by current clients

Key findings

1. **Most servers are fine, and the ones that aren't share the same few gaps.** 61% pass every check, and the median score is 100/100. Three issues account for most deductions: Origin validation, safety annotations and description length.
2. **Origin validation is the most-skipped MUST in the spec.** 44% of public servers process requests carrying a foreign `Origin` header, and 22% answer with `Access-Control-Allow-Origin: *`.
3. **Agents often can't tell safe tools from dangerous ones.** 22% of public servers ship tools without `readOnlyHint` / `destructiveHint` annotations. 5% have tools named like writes (create, update, delete, send) with no annotation at all.
4. **The context bill is concentrated in a few large servers.** The median public server exposes 7 tools. The top 10% expose 26 or more, and the largest exposes 1,040. 2,995 individual tool descriptions exceed 1,500 characters, 571 exceed 3,000, and the longest is 27,638 characters.
5. **OAuth is mostly right, and when it's wrong, nobody can log in.** 87% of login-protected servers pass discovery cleanly. 10% publish no RFC 9728 protected-resource metadata, or only the older 2025-03-26 flow. 7% return a 401 with no `WWW-Authenticate` header. 30 point clients at a metadata URL that doesn't load.

1. Scores

Score distribution (all reachable servers)



Public vs login-protected

	Servers	Score 100
Public (tools listed without login)	**8,430**	**40%**
Behind a 401	**6,637**	**87%**
Unreachable / not MCP	**1,006**	**n/a**

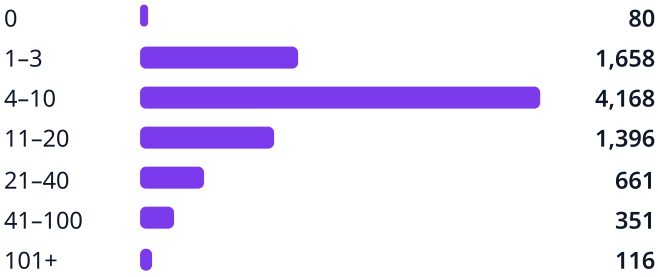


Login-protected servers are scored on their discovery flow only. The tool surface behind login isn't visible to an unauthenticated scan.

2. Gaps on public servers

Gap	Share of 8,430 public servers	Why it matters
Foreign `Origin` accepted	44%	Spec MUST; DNS-rebinding and drive-by calls from any web page
No / missing safety annotations	22%	Clients can't decide when to ask the human first
`Access-Control-Allow-Origin: *`	22%	Any site can call the server from a visitor's browser
Unknown method ≠ `-32601`	13%	Breaks capability probing in some clients
A tool description over 1,500 chars	10%	Paid on every turn, by every user
No human-readable tool titles	20%	Approval prompts show raw identifiers
Write-sounding tools, no annotations	5%	Delete looks the same as list
More than 40 tools	6%	Exceeds some clients' tool caps; heavy context
Untyped input properties	3%	Model guesses the shape; failed calls cost money
Outdated protocol version	2%	Misses newer features (annotations, structured output)

Tools per public server



What "too long" looks like

Tool metadata goes into the model's context on every turn, whether or not the tool is used. Rule of thumb: 4 characters ≈ 1 token.

- A clean tool: 150–600 characters
- Our warning threshold: 1,500 characters
- Longest single description found: **27,638** characters (≈6,910 tokens)
- Largest `tools/list` measured: ≈505 KB (≈125K tokens) for one analytics vendor

3. Authentication and discovery

For a server to work as a one-click connector in Claude.ai or ChatGPT, it has to support the 2025-06-18 discovery chain: a `401` with `WWW-Authenticate: Bearer resource_metadata="…"`, then RFC 9728 protected-resource metadata, then RFC 8414 authorization-server metadata with PKCE S256, ideally with dynamic client registration.

Issue (login-protected servers, n=6,637)	Count / share
No RFC 9728 metadata, or legacy 2025-03-26 flow only	**10%**
401 without `WWW-Authenticate`	**7%**
Legacy discovery (AS metadata on the MCP host, no RFC 9728)	**23**
`resource_metadata` pointer that returns an error	**30**
`resource_metadata` given as a relative URL	**2**
Authorization server without PKCE S256	**5**

Many servers behind a 401 use plain API keys on purpose. For those, missing OAuth metadata isn't a bug, but it rules out the consumer connector directories.

4. Patterns from the long tail (anonymized)

The 628-tool ad server. A mature ad-serving platform generated its MCP server from its REST API. Every endpoint became a tool, and about 300 create/update/delete tools have no annotations. The surface is complete, but agents get no safety signal and spend about 80K tokens per turn.

The 125K-token analytics server. 132 tools with rich descriptions and untyped SQL-like `where` / `having` arguments. Next to two other servers it no longer fits in a typical context window.

The broken pointer. Several SaaS vendors, including an SMS platform and an integration platform, return a correct-looking `401` whose `resource_metadata` URL returns 404. Their own docs say "ChatGPT isn't supported", and this is why.

The callback form. A well-built comparison site exposes a "request a callback" tool that submits a phone number. Combined with `CORS: *` and no Origin check, any web page can file leads through its visitors' browsers.

The false alarm. Our first pass flagged 244 servers for tool poisoning. Most were harmless lines like "read-only, needs no API key". After the rule was narrowed, the remaining flags are mostly invisible bidi characters in legitimate right-to-left text. Automated poisoning checks need a human read before anyone is accused of anything.

5. What the leaders do

A separate scan of 25 well-known vendor servers (Stripe, Notion, Linear, Sentry, GitHub, Supabase, Vercel, PayPal, Cloudflare, Microsoft Learn and others) found 20 of 25 at 100/100. Their shared habits:

- A full OAuth 2025-06-18 discovery chain with PKCE S256.
- Few, well-named tools (2–5 on public docs servers) with short descriptions.
- Annotations on every tool, including `readOnlyHint` on pure reads.
- Origin validation on anything that isn't purely public and read-only.

6. A checklist for MCP server owners

1. Validate `Origin`, and drop wildcard CORS on any server with write tools.
2. Annotate every tool. If you have an OpenAPI spec, generate the annotations from the HTTP verbs.
3. Keep descriptions under about 600 characters. Put shared guidance in the server's `instructions` field.
4. Over about 40 tools, split them into toolsets or use a search-then-load pattern.
5. Type every input property and list the required ones.
6. For OAuth, return `401` + `WWW-Authenticate` with an absolute `resource_metadata` URL, publish RFC 9728 and RFC 8414 metadata, and support PKCE S256.
7. Return `-32601` for unknown methods.
8. Re-scan on every release. The scanner runs in CI in under a second per server.

Method

Source: the official MCP registry API (registry.modelcontextprotocol.io), latest version of each server, Streamable-HTTP remotes only, deduplicated to one endpoint per registered domain. Probes, all unauthenticated and with no side effects: `initialize`, `tools/list`, `prompts/list`, an unknown method, an unknown tool name, a request with a foreign `Origin`, a CORS preflight, and OAuth discovery (RFC 9728, RFC 8414, legacy 2025-03-26, PKCE, DCR). 20-second timeout, run on 13 Nov 2026. Scores are the scanner's weighted deductions (fail −15, warn −5) and are a triage signal, not a security audit. Small vendors are anonymized. Vendors named in section 5 were scanned on public endpoints and are named only for positive practice.

Want this for your server, public or internal? The MCP Readiness Review covers the automated scan, a manual review of auth and approval gates, a ranked fix plan and a re-scan in 3 working days. Omer Shacham · [email] · [LinkedIn URL]